Software Engineering Lab Coursework

Lab 5: Static Code Analysis (Pylint, Bandit, Flake8)

Student Name	Shakthi Raja G P
SRN & Section	PES1UG25CS843 | Section L (Semester 5)
Assigned Script	attendance_tracker.py (Problem Statement / Row 60)
Assigned Repository	https://github.com/SETAPESU26/L5_61_attendance-tracker
Static Analysis Tools	Bandit 1.9.4, Pylint 4.1.3, Flake8 7.4.1

1. Introduction & Objectives

The objective of this lab is to utilize static code analysis tools (Pylint, Bandit, and Flake8) to analyze, detect, and fix code quality issues, security vulnerabilities, and PEP 8 style violations in an assigned Python application (attendance_tracker.py) without executing the code. Through an iterative review process, issues were classified, documented, and resolved across dedicated tool commits.

2. Static Analysis Tools Utilized

• Bandit: Analyzes Python code to identify common security issues, dangerous function calls, and vulnerability patterns.
• Pylint: Checks for programming errors, enforces a coding standard, detects code smells, and scores code quality.
• Flake8: Enforces PEP 8 style guidelines, checking for whitespace, indentation, line lengths, and syntax issues.

3. Static Analysis Metrics Comparison

The table below summarizes the tool metrics before and after the refactoring:

Static Analysis Tool	Baseline (Before)	Target Threshold	Final State (After)
Bandit (Security)	8 issues (2 High, 3 Med, 3 Low)	0 High/Medium issues	0 issues (PASSED)
Pylint (Quality & Logic)	4.55 / 10	Score > 9.50 / 10	10.00 / 10 (PERFECT)
Flake8 (PEP 8 Style)	25 style violations	0 errors	0 errors (PASSED)

4. Issue Tracking and Remediation Table

The table below documents the identified defects across the tools and the remediation approaches applied:

Issue Code	Tool / Severity	Line	Defect Description	Applied Remediation
B501	Bandit (High)	60	requests.post with verify=False disables SSL certificate verification.	Removed verify=False to enforce default SSL/TLS certificate checking.
B609 / B602	Bandit (High/Low)	64	subprocess.Popen with shell=True and wildcard *.csv risks command injection.	Replaced subprocess with Python native tarfile and glob modules.
B113 / W3101	Bandit / Pylint (Med)	60	HTTP request lacks timeout, which can cause indefinite hanging.	Added explicit timeout=10 parameter to requests.post.
B503	Bandit (Med)	66	legacyChannel defaulted to deprecated ssl.PROTOCOL_TLS v1.	Updated default parameter to modern ssl.PROTOCOL_TLS _CLIENT.
W0102	Pylint (Bug)	18	Dangerous mutable default argument register={} shared across all calls.	Changed default to register=None and initialized target_register inside function body.
R1719 / Logic	Pylint (Bug)	30	isEligible used redundant ternary and excluded 75% boundary (> 75).	Refactored to return percentage >= MIN_ATTENDANCE .
C0103 / C0116	Pylint (Quality)	15-75	camelCase naming style and missing docstrings across functions.	Converted to snake_case and added complete docstrings.

5. Git Commit Verification History

The required tool-based iterative commits were executed cleanly:
• Initial Starter: 0aa4b75 - feat(lab-05): add initial attendance tracker starter code and baseline reports
• Commit 1 (Bandit): 4059630 - fix(lab-05): resolve bandit security issues with ssl, subprocess, and requests
• Commit 2 (Pylint): 06f1afa - refactor(lab-05): fix pylint code quality issues, mutable default args, and add docstrings
• Commit 3 (Flake8): 1724ef9 - style(lab-05): resolve flake8 formatting, line lengths, and pep 8 style issues